

Sprint #2 Release Demo Self-Grade

Oct 9, 2026 · @Erin Hasani

Summary

Estimated score: **13 of 19** across the four Release Demo rows graded here. The Scrum board subsection is left for a manual check. Release is the weakest row: sprint work sits on unmerged branches and open PRs with no explanation, and `origin/main` and `origin/dev` have diverged, so PROD is missing nearly all of Sprint 2.

Rubric row	Max	Estimated grade	Deciding factor
Usability	4	3	No crashes in 140 browser tests, but prototype controls, browser-only courses and an unverified TEST database could trip an untrained user
Sizing and Security	5	5	Argon2id or bcrypt via <code>password_hash</code> (salted by design); layouts tested at 375–1440 px
Requirements	5	3	Story 114 departs from the "so that" template, and some cards describe an API that the code mocks
Release	5	2	6 task branches are unmerged into <code>dev</code> , 2 PRs are open with 0 comments, and some merged work has no story

Evidence comes from `dev` at `9d22313` on 2026-10-09: `tsc` clean, 104 Vitest tests passing with 1 `todo`, PHP security tests passing, and 140 Playwright tests passing on desktop and mobile Chromium. The Playwright suite mocks the PHP API, so it does not prove the deployed backend works.

Usability — 3 of 4 (Satisfactory)

The sprint features work and are tested, so this row clears Unsatisfactory. It sits at 3, not 4, because several rough edges could confuse an untrained user or turn into a functional bug at the demo. The rubric has no Exemplary band for this row.

Evidence for the grade

- All 140 Playwright tests pass on desktop and iPhone 13 Chromium, including create, rename, edit, delete (list and editor), pinning, comments, history and uploads.
- Note deletion follows story 114 closely: a confirmation dialog, a "Note deleted." toast, the result persists after reload, and a dead link shows "We couldn't open that note".
- An axe-core scan reports zero WCAG 2.1 AA violations, and the app respects reduced motion, high contrast and 200% text size.

Flaws found

- **The deployed backend may not match the code.** As of the last check, migrations 002–004 had not been confirmed on the aptitude TEST server. If they are missing, every server note route fails (likely a 503) during the demo. That is a functional bug and drops this row to 0.
- **The browser tests never touch the real API.** Every Playwright run logs `ECONNREFUSED 127.0.0.1:8080` because the API is mocked. Nothing automated proves that sign-up, then a note save, works end to end against PHP and MySQL.
- **Prototype controls show up in the real UI.** The import dialog has a "Prototype preview options" control, and document extraction is simulated. To a grader this looks unfinished.
- **Courses and events live only in the browser.** They are lost when you switch devices or clear storage, while notes persist on the server. A collaborator sees a shared note's course as its category, which reads as a display bug.
- **The demo workspace still uses the collaborator mock.** Only `jamie@example.edu` can be invited in the demo, and invitations disappear on reload (see the `it.todo` in `comments-integration.test.ts`).
- **Account recovery is unforgiving.** Without the recovery code an account is gone for good, and no email is ever sent. An untrained user who skims past "I saved my recovery code" can lock themselves out.
- **Password rules can surprise users.** Passwords must be printable ASCII, at most 72 characters. A passphrase containing an accented letter is rejected.

Sizing and Security — 5 of 5 (Exemplary)

Passwords are hashed and salted, and the layout has breakpoints and tests for phone, tablet and desktop widths. That meets every Exemplary condition. The risks below are about coverage gaps a grader could hit on a real device.

Evidence for the grade

- `hashPassword()` in `backend/lib/security.php` calls `password_hash` with Argon2id when available, otherwise `bcrypt` at cost 12. Both generate a random per-password salt and store it inside the hash.
- On login, `password_needs_rehash` upgrades old hashes, and `password_verify` checks them. No plaintext is stored or logged.
- `App.module.css` has breakpoints at 360, 767, 1023, 1250 and 1600 px. Tests check for no sideways scrolling at 375, 768, 1024 and 1440 px, at 200% text, and on iPhone 13, Firefox and WebKit.
- Extra hardening beyond the rubric: CSRF tokens, `Secure` session cookies, rate limits on login, signup, reset and invites, and a check that rejects common passwords.

Flaws found

- **"All screen sizes" is not proven at the extremes.** No test runs at 320 px (iPhone SE) or in landscape phone sizes such as 844×390. The tightest breakpoint is 360 px.
- **The accessibility scan covers one page at one size.** axe runs only on the dashboard at 1440 px, not on Notes, the editor, dialogs or mobile layouts.
- **No test runs on a real touch device.** Mobile coverage is Chromium emulating an iPhone, not Safari on iOS.
- **The breached-password list is tiny.** `COMMON_PASSWORDS` holds about 50 entries, and the code comment admits it is a placeholder.
- **The `.htaccess` protection is ignored on aptitude.** The server ignores `.htaccess`, so `backend/lib` depends on the PHP `NOTELY_INTERNAL` guard and the config folder ACL. This is deliberate and it works, but a misconfiguration would expose files.

Requirements — 3 of 5 (Satisfactory)

Most stories and most features line up, which earns Satisfactory. Exemplary requires *all* of them to match, and at least one story and several task cards do not.

Evidence for the grade

- Story 114 (delete a note) has 7 acceptance tests a typical user can run: exact inputs and expected text, a phone pass, and cleanup.
- Each of task cards 115–120 has its own task tests, and the merged code passes them (`note-delete.php` , `delete-note-*.spec.ts` , `note-deletion-integration.spec.ts`).
- Duplicate cards 111 and 112 were closed with PRs that explain the duplication (#46, #47).

Flaws found

- **Story 114 departs from the template.** It reads "I want to delete a note..., *which is confirmed by* the note disappearing". The template is "As a ..., I want ..., so that ...", and this story has no "so that" benefit.
- **Story 114's acceptance tests use two addresses.** Test 1 uses the cattle URL, while Test 7 says "open the PROD address" without giving it. A grader cannot run Test 7 as written.
- **Some task cards describe work the code doesn't do.** Card 70 says permissions are stored "via the API", but they live in `collaborators.mock.ts` and are lost on reload. A grader comparing the card to the build will mark it unmet.
- **The README promises more than the stories deliver.** It lists version history with restore, but the version history cards (56, 57) were still in progress this week. Branch 56 has an unmerged commit from 2026-10-08.
- **There is a known failing case.** The `it.todo` for "collaborator access survives a reload" shows a behaviour the comment stories imply but the build does not support.
- **Story coverage cannot be confirmed for all of Sprint 2.** Only story 114 was checked word for word here. The other Sprint 2 stories should be checked against the template on the board.

Release — 2 of 5 (Developing)

Every shipped file is in the repo, and most functionality traces to a story. Satisfactory requires *all* functionality to come from a story, though, and unfinished tasks need comments explaining them. Both conditions fail today.

Evidence for the grade

- `npm run build` produces the release from tracked files only. The only file kept outside the repo is the DB config, which holds credentials and is allowed.

- 38 PRs were merged into `dev`, most named after their card (for example `118-frontend-delete-note-from-notes-page`).

Flaws found

- **Some merged work has no story.** PRs #17 `streamline-signup-settings`, #18 `ascii_security`, #19 `fix-stacked-accents` and #15/#16 `fix-aptitude-configuration` have no card number. The security hardening from closed PR #45 was folded into task 120, a deletion card. A grader can count all of these as unspecified functionality.
- **Unfinished tasks have no explanation.** PR #27 (`106-save-new-note`) and PR #9 (`29-investor-story-account-poc`) are open with 0 comments.
- **Task branches are unmerged into `dev`.** `106-save-new-note`, `35-automatically-organize-uploaded-class-notes`, `54-note-search-interface` and `56-store-note-version-history` each hold commits that are not in `dev`. Each needs a merge or a card comment explaining why not.
- **`origin/main` and `origin/dev` have diverged.** `main` has 1 commit ("Meeting Notes") that is not in `dev`, and `dev` has 133 commits that are not in `main`. The TA treats `main` as PROD and `dev` as TEST, so almost none of Sprint 2 is on PROD yet. If the demo runs on PROD, the sprint features are simply missing.
- **Stale and duplicate branches add noise.** The remote has 53 branches, including `codex/107-frontend-edit-note-title`, two `92-*` branches, and `120-security-hardening` from a closed PR.
- **The deployed build may lag the repo.** Migrations 002-004 still need to be confirmed on TEST. A release that runs older code than the repo fails the "files in the repo" spirit of this row.

Fixes, most urgent first

Items 1, 2, 3 and 5 each risk a 0 on a row, so do them before the demo.

#	Flaw	Row at risk	Fix
1	Migrations 002-004 not confirmed on TEST	Usability, Release	Apply them with <code>devwork-ai/DEPLOY_TO_APTITUDE.md</code> , then run <code>npm run test:schema</code> and story 114's acceptance tests on the live URL

#	Flaw	Row at risk	Fix
2	Open PRs #27 and #9 have no comments	Release	Merge them, or close each with a comment explaining the blocker and the steps taken
3	Unmerged branches 106, 35, 54, 56	Release	Merge each, or comment on its card explaining why it is incomplete
4	Merged work with no story (PRs #15–#19, security hardening)	Release	Attach each to an existing story or add a story card that covers it
5	PROD (<code>main</code>) is 133 commits behind TEST (<code>dev</code>)	Release, Usability	After item 1 passes on TEST, merge <code>dev</code> into <code>main</code> (pulling in the "Meeting Notes" commit first), deploy PROD, apply migrations 002–004 there, and rerun story 114's tests on PROD
6	Story 114 has no "so that" clause	Requirements	Rewrite it as "...so that my notes list only shows notes I still need"
7	Story 114 Test 7 says "PROD address"	Requirements	Replace it with the actual URL
8	Card 70 says "via the API" but uses a mock	Requirements	Edit the card to say what shipped, or finish the server version
9	Prototype preview control visible	Usability	Hide it behind a URL flag for the demo
10	No 320 px or landscape-phone tests	Sizing	Add 320×568 and 844×390 to the responsive test
11	axe scans one page only	Sizing	Run axe on Notes, the editor and the delete dialog at 375 px
12	53 remote branches, some stale	Release	Delete branches whose PRs are merged or closed